00 | Enterprise AI platform: target reference architecture

Microsoft-only stack. Agents run on AKS; models, AI Search and Document Intelligence stay in Foundry. One gateway pattern for every application.

ONLINE REQUEST PATH: AUTHENTICATED, AUTHORISED AND TRACED END TO END

Users, Teams, Web
Entra ID, Conditional Access, MFA

→

Front door (optional)
App Gateway WAF only where public ingress is needed

→

APIM: app gateway
JWT validation, per-app product, quotas

→

AKS: agent runtime
Namespace per app, Agent Framework

→

APIM: AI gateway
Token limits, routing, cache, safety hook

→

Microsoft Foundry
Shared models, guardrails, evaluations

private endpoints

PRIVATE LINK SERVICES: PUBLIC ACCESS DISABLED, ONE SCOPED IDENTITY PER APPLICATION

Azure AI Search
Evidence index, ACL trimming

Cosmos DB
Conversations and run state

Azure Cache for Redis
Session memory, semantic cache

Service Bus
Jobs, actions, dead letters

Blob Storage
Source versions, staging

Document Intelligence
OCR and layout, batch path only

Key Vault
Secrets, certificates, CMK

Container Registry
Signed, versioned app images

CROSS-CUTTING PLANES: THEY APPLY TO EVERY APPLICATION, THEY ARE NOT REQUEST HOPS

Ingestion plane
Blob, Document Intelligence, chunk, embed, Search
KEDA-scaled jobs on AKS (spot)
ACLs carried into the index

Governance and security
Entra workload identity, Key Vault
Firewall egress allowlist, Azure Policy
Defender, Purview, Sentinel
Prompt Shields, content safety

Operations
OpenTelemetry traces end to end
Azure Monitor, alerts, SLOs
GitOps with Flux or Argo
Azure DevOps private agents

FinOps
Token quota per app at the AI gateway
Chargeback from gateway metrics
PTU baseline, pay-as-you-go spill
Tags, budgets, reservations

Resilience
Zonal AKS, zone-redundant PaaS
Warm standby in the paired region
Multi-region Cosmos DB
Gateway fails over model backends

Changes from the previous sheet 00: APIM split into app gateway and AI gateway roles. Redis, ingestion plane, tool gateway and guardrails added. Namespace-per-app model inside AKS. DR and FinOps planes added. Front door made optional for internal-only apps.

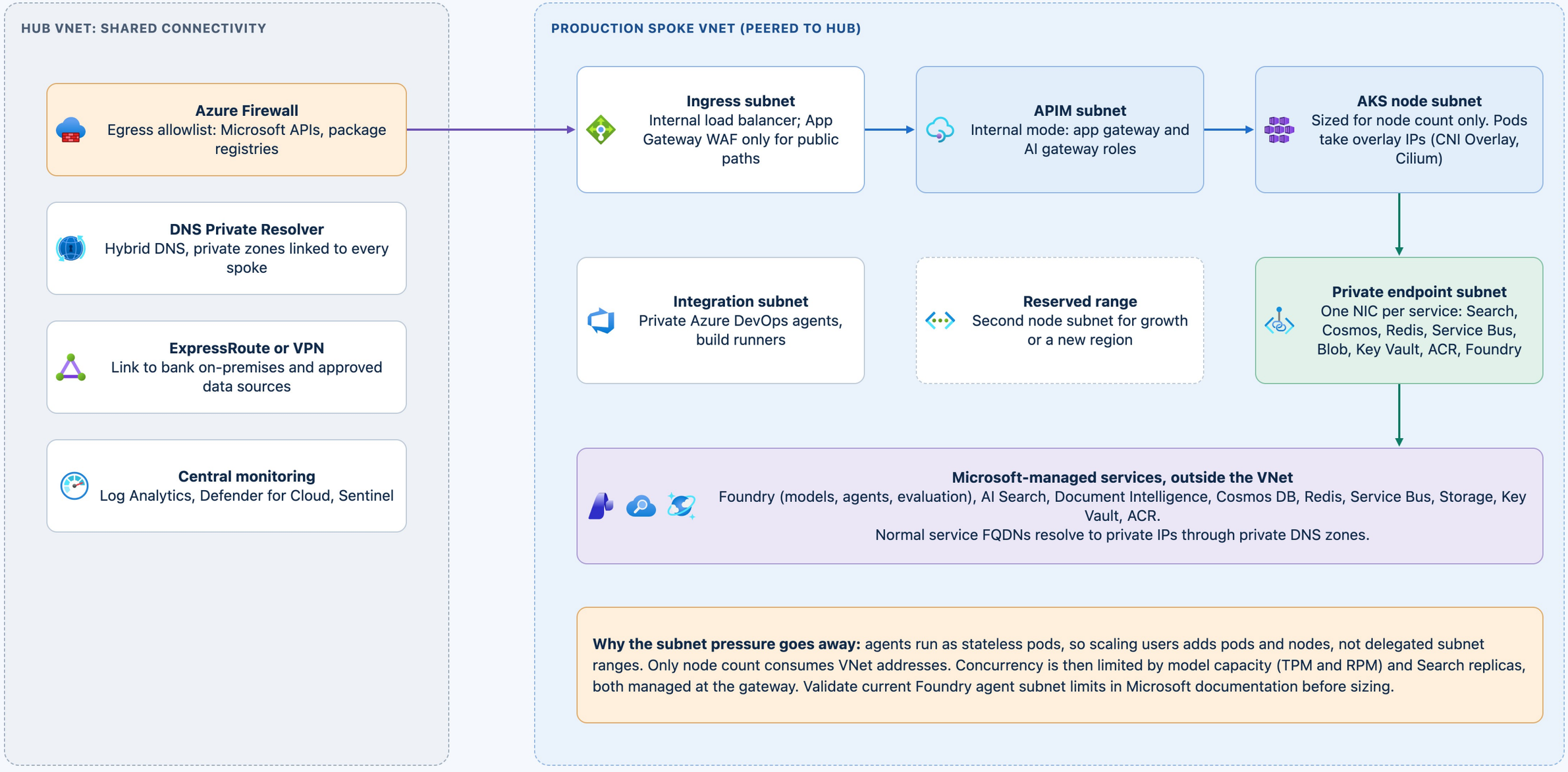
PROPOSED DESIGN, 24 OCT 2026. Sheets 01 to 06 detail network, request flow, AKS runtime, ingestion, security and templates. Validate current service limits against Microsoft documentation before build.

Icons: Microsoft Azure Public Service Icons V24. Document Intelligence uses the Form Recognizers icon (its former name). Purview and Teams have no icon in the pack, so they appear as text only.

Blue arrows: application traffic. Green: Private Link. Orange tint: AI gateway. Purple: Foundry.

01 | Network placement and the subnet-size fix

Hub provides connectivity and control. The production spoke hosts AKS and APIM. Managed services are reached over Private Link.

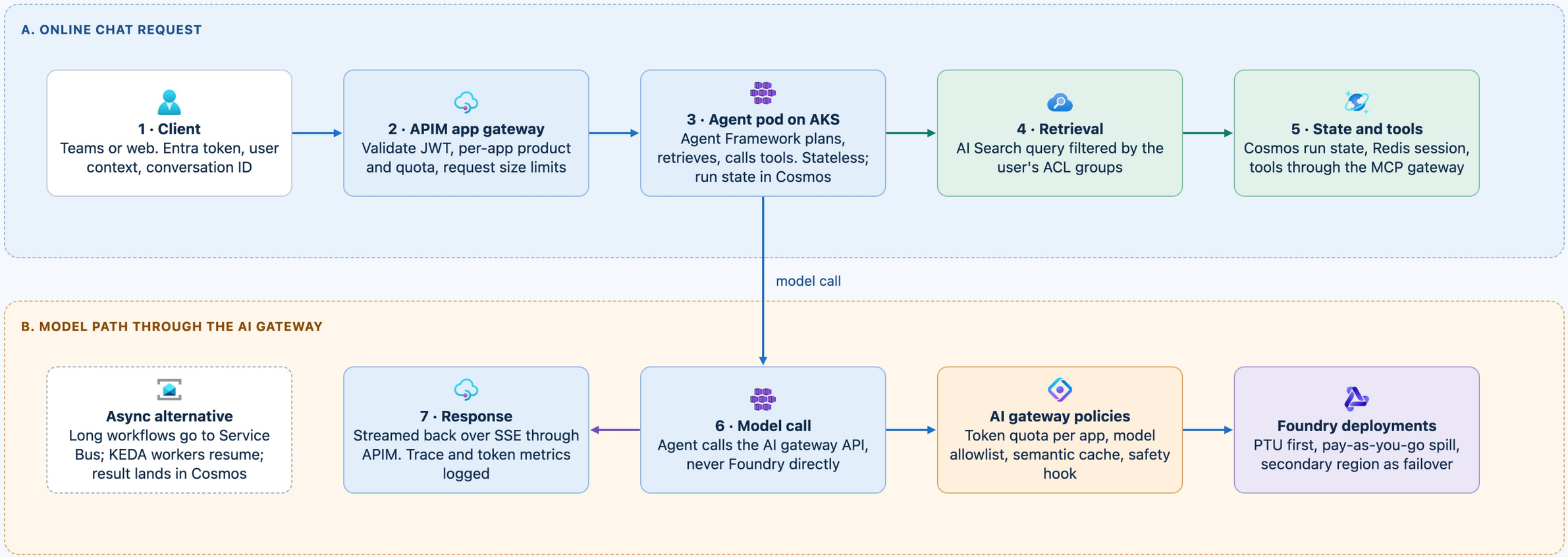


PROPOSED DESIGN, 24 OCT 2026. No CIDRs shown on purpose: allocate from the enterprise IPAM and size the node subnet for peak node count plus upgrade surge.

Blue arrows: application traffic. Green: Private Link. Purple: peering and shared control. Orange: controlled egress.

02 | Request flow and the AI gateway

Every model call passes one gateway, so quotas, caching, safety and chargeback are enforced once for all applications.



Enforced at the AI gateway, per app and per tier: token-per-minute quota and monthly budget. Model allowlist and routing (small model for classification and extraction, large model for reasoning). Semantic and prompt caching. Prompt Shields and content-safety hook on input and output. Circuit breaker and regional failover across deployments. Token metrics per app sent to Azure Monitor for chargeback.

PROPOSED DESIGN, 24 OCT 2026. Internal-only apps skip the front door and enter through APIM alone, which saves a gateway hop and its cost.

Blue arrows: application traffic. Green: Private Link access to data. Purple: response path.

03 | AKS multi-tenant runtime: one namespace per application

Shared platform services once; each application is a template instance with its own identity, quota and network policy.

AKS CLUSTER: PRIVATE, ZONAL, CNI OVERLAY WITH CILIUM, NODE AUTO-PROVISIONING, KEDA

NAMESPACE: PLATFORM (SHARED SERVICES, OWNED BY THE PLATFORM TEAM)

- **Ingress** — Internal load balancer, TLS, APIM as backend caller
- **Agent base image** — Shared library: auth, tracing, guardrails, retries
- **MCP and tool gateway** — Tool registry, allowlist, per-tool scopes
- **Ingestion workers** — KEDA jobs: parse, chunk, embed
- **Observability** — OpenTelemetry collector, Prometheus, log agents
- **Policy** — Gatekeeper, default-deny NetworkPolicy, quota templates

NAMESPACE: APP-HR-ASSISTANT (TIER 3, SHARED)

- **Fixed RAG** — Stateless pods, HPA on concurrency
- **Own boundary** — Workload identity, ResourceQuota, NetworkPolicy, Helm release

NAMESPACE: APP-BANKING-AGENT (TIER 1, DEDICATED)

- **Multi-agent** — Stateless pods plus queue workers
- **Own boundary** — Workload identity, ResourceQuota, NetworkPolicy, Helm release

NAMESPACE: APP-CONTRACT-RAG (TIER 2, SHARED)

- **Agentic RAG** — Stateless pods, async jobs for long runs
- **Own boundary** — Workload identity, ResourceQuota, NetworkPolicy, Helm release

NODE POOLS

- **System pool** — Add-ons and system pods, zonal, small SKUs
- **Agent pool** — Agent and API pods, autoscaled, zonal
- **Batch pool (spot)** — Ingestion and evaluation jobs, scale to zero
- **GPU pool (optional)** — Classical ML inference only, scale to zero

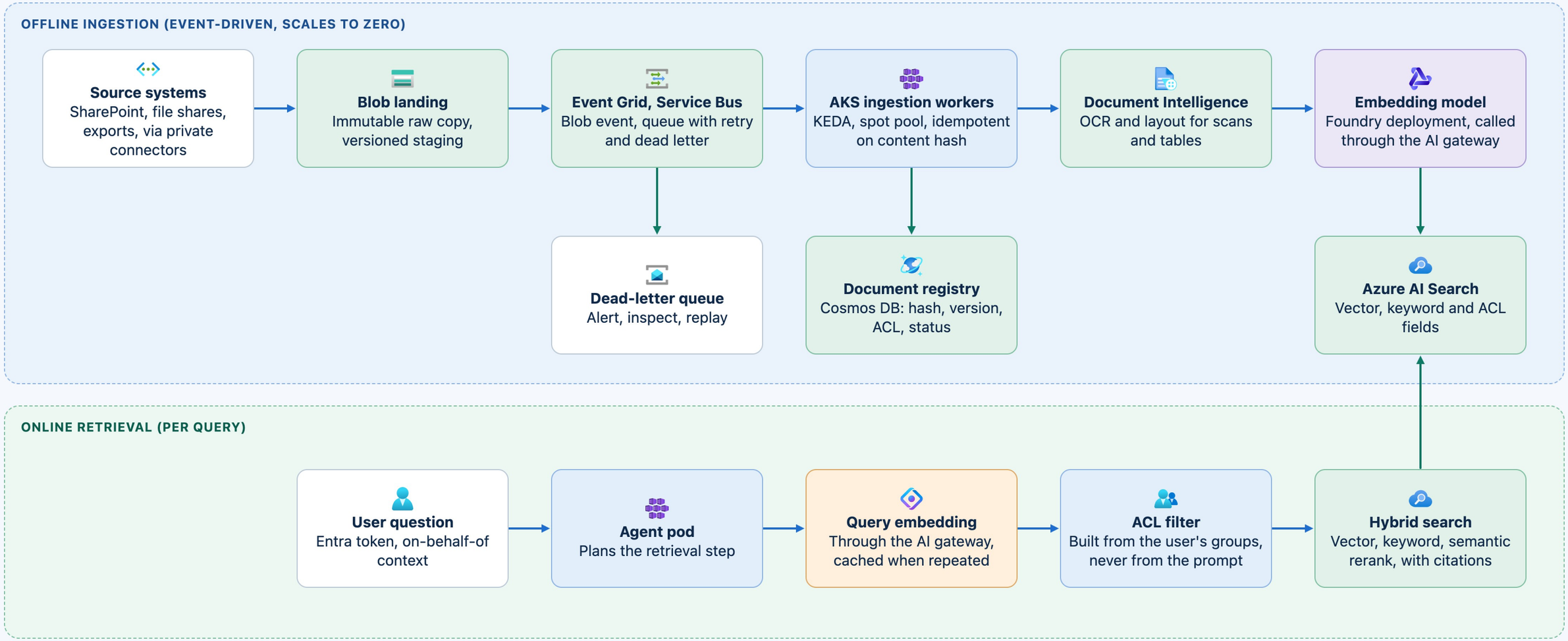
Egress rules: models only through the APIM AI gateway, tools only through the MCP gateway, everything else through the Azure Firewall allowlist. Images come from Container Registry, signed and admitted by policy.

PROPOSED DESIGN, 24 OCT 2026. Namespace-per-app suits shared tiers; Tier 1 apps can move to a dedicated node pool or cluster without changing the template.

Scaling: HPA and KEDA on concurrency or queue depth for pods; node auto-provisioning for nodes; pods are stateless with state in Cosmos and Redis.

04 | Ingestion plane and secure retrieval

Document processing is an offline, event-driven pipeline. The online path only queries the index, with the user's ACLs applied.



Design rules: ACLs captured at ingestion and stored as index fields for security trimming. Raw copy kept immutable so the index can be rebuilt. Workers are idempotent on content hash. Document Intelligence runs only in the batch path. Dedicated index per Tier 1 app; shared index with a tenant filter for Tier 2 and 3.

PROPOSED DESIGN, 24 OCT 2026. Re-index on embedding-model change is a batch job on the spot pool, not an online operation.

Blue arrows: processing flow. Green: Private Link access. Orange tint: AI gateway. Purple: Foundry.

05 | Security and governance for a banking AI platform

Six control layers apply to every application, so a team onboarding through the template inherits them instead of rebuilding them.

1 · Identity and access

Entra ID with Conditional Access and MFA for users.
Workload identity per app; no secrets in pods.
Least-privilege RBAC on every PaaS resource.
On-behalf-of tokens: retrieval and tools run as the user.
Agent identity for non-human actors where available.

2 · Network and egress

Private endpoints everywhere; public network access disabled.
Private AKS cluster and internal-mode APIM.
Azure Firewall FQDN allowlist for all egress.
Private DNS zones linked from the hub.
Default-deny NetworkPolicy in every namespace.

3 · Data protection

Customer-managed keys via Key Vault where required.
TLS in transit; encryption at rest on all stores.
Purview classification and sensitivity labels.
PII redaction before anything reaches logs.
Check data residency of each model deployment type (regional, data zone, global) against CBUAE and internal rules.

4 · AI-specific controls

Prompt Shields and content safety on input and output.
Tool allowlist per app in the MCP gateway.
Human approval and idempotency keys for write actions.
Grounding checks and citations on answers.
Evaluation gate before release: quality, safety, red team.

5 · Platform hardening

Signed images; admission through Azure Policy and Gatekeeper.
Defender for Containers and Defender for Cloud.
Private build agents; no public runners.
Regular node image upgrades.
Separate subscriptions for production and non-production.

6 · Audit and compliance

Prompts, responses and tool calls logged with PII controls.
Retention per bank policy; immutable storage for audit trail.
Sentinel detections for abuse and data exfiltration.
Model and prompt versions recorded per release.
Periodic access reviews per application.

THREAT TO CONTROL MAPPING

Threat	Primary controls
Prompt injection, direct or through documents	Prompt Shields, content isolation, tool allowlist, output checks
Cross-user data leakage	ACL trimming from user groups, on-behalf-of identity, per-app index or tenant filter
Over-privileged agent actions	Per-tool scopes, human approval for writes, idempotency keys
Cost runaway or model abuse	Token quotas, circuit breaker, budgets with alerts per app
Supply-chain compromise	Signed images, private registry, admission policy, image scanning
Sensitive data in logs	PII redaction, restricted log workspaces, retention policy

PROPOSED DESIGN, 24 OCT 2026. Map each control to the bank's own control framework and regulator requirements before sign-off.

Blue: identity. Green: network. Purple: data. Orange: AI-specific. White: platform and audit.

06 | App factory, tiers and capacity sizing

New applications are onboarded from templates, placed in a tier, and sized from concurrent users down to pods.

APP FACTORY: ONBOARDING BY PULL REQUEST

1 · App manifest PR
Pattern, tier, owners, data sources, quota request

›

2 · Automated gates
Security scan, evaluation set, cost estimate, policy check

›

3 · Landing-zone module
Namespace, identity, APIM product and quota, index, container, queue, Key Vault access, dashboards

›

4 · Pattern deploys
Helm chart from the catalog, shared base library

›

5 · GitOps promotion
Dev, test, production with approvals

PATTERN CATALOG: ONE TEMPLATE PER APPLICATION TYPE

Fixed RAG
Retrieve, answer, cite

Agentic RAG
Plan, retrieve, reflect, call tools

Multi-agent
Supervisor and specialist agents

ML inference
Model service, optional GPU pool

Async workflow
Queue-driven, approval steps

TIERS: WHAT EACH APPLICATION GETS

Tier 1 · Critical

Dedicated Search index and Cosmos container.
Dedicated node pool, or cluster if required.
Multi-region active-passive with tested failover.
Reserved PTU capacity for baseline load.
Availability and latency SLOs agreed with the business owner.

Tier 2 · Standard

Shared index with tenant filter, shared Cosmos account.
Zonal AKS in the primary region, backup in the paired region.
Quota from a shared PTU pool, pay-as-you-go spill.
Standard SLOs; chargeback by token usage.

Tier 3 · POC

Shared everything, low token quota.
Scale to zero outside working hours.
No DR; environment expires after its review date.
Promotion to Tier 2 needs the same gates as production.

CAPACITY SIZING CHAIN: FROM USERS TO PODS

Demand
Concurrent users × requests per minute × tokens per request

›

TPM and RPM per app
Quota set at the AI gateway

›

Model deployments
PTU baseline, pay-as-you-go spill

›

Data services
Search replicas, Cosmos RU, Redis size

›

AKS pods and nodes
HPA, KEDA, node auto-provisioning

Validate before go-live: set SLOs per tier (p95 time to first token, availability, error budget), load-test the full chain, and repeat at every tier change.

PROPOSED DESIGN, 24 OCT 2026. Tier definitions are a starting point; agree the final limits and SLOs with application owners and risk.

Bottleneck note: with CNI Overlay the first limits hit are model TPM and RPM and Search replicas, not subnet addresses.

07 | Application view: HR Buddy on the shared AI platform (production design)

Template instance of the platform: one namespace, one identity, one token budget. Reference for any new RAG or agentic application.

Employees
Teams or internal web
Entra ID, MFA

App Gateway WAF v2
Private HTTPS, TLS
Only if public path

APIM: app APIs
JWT check, quota
Versioning, WAF rules

Azure Kubernetes Service

Private, zonal, CNI Overlay. Namespace app-hr-buddy

HR Buddy web and API
Entra token validated, conversation owner check
Request admission, SSE streaming to the client
Response validation: citations present, no raw HR data

Agent orchestration and context
Microsoft Agent Framework, bounded workflows
Policy RAG, HR lookup, approved-action routing
Scoped memory, tool allowlist, step and token budgets
Stateless pods; state in Cosmos DB and Redis

Action and workflow workers
Authorization re-check, idempotent execution
KEDA on queue depth, dead-letter handling

HR integration and tool gateway
Per-tool scopes, on-behalf-of token for the user
Human approval for write actions

Ingestion workers (spot pool)
Extract, chunk, embed, publish to the index
Idempotent on content hash, KEDA on queue

Additional internal applications and ML
Same trust boundary, own namespace, identity and quota
Deployed from the pattern catalog

Managed AI and data services

Logical view. Private endpoints and DNS on sheet 01

APIM AI gateway
Model API from AKS
Token budget per app
Cache, routing, failover

Microsoft Foundry
Chat and embedding models
PTU base, pay-as-you-go spill

Azure AI Search
Hybrid and semantic rank
ACL trimming filters

Content Safety
Prompt Shields, filters
Input and output checks

Azure Cosmos DB
Conversations, run state
Approvals, action state

Azure AI Speech
Optional voice adapter
Separate stream budget

Azure Cache for Redis
Session memory
Semantic and prompt cache

Azure Service Bus
Jobs, retries, dead letters
Premium, private access

Document Intelligence
Optional OCR and layout
Scans, complex PDFs

Secondary region (warm standby)
AKS at minimum scale, same Helm release from GitOps
Cosmos DB with a second region and tested failover
Search replica rebuilt from the Blob source of truth
Second model deployment behind the gateway
APIM and DNS failover by traffic manager
Failover drilled every quarter

Bank HR systems
Approved APIs only
System of record

ExpressRoute or VPN
Private path to the bank network

Azure Firewall
FQDN egress allowlist
Logged and alerted

Approved HR documents
Controlled uploads
Source permissions

Blob Storage
Versions, artifacts
Private endpoint

Event Grid
Blob events to the Service Bus queue

REQUEST PATH

Authenticate → authorize → retrieve → generate → validate → respond

Policy answers cite sources. Personal data comes only from HR APIs, as the signed-in user.

Write actions need user confirmation, then approval workflow and an idempotency key.

Every model call passes the AI gateway, including embeddings from ingestion (arrow omitted).

Blue: application and HR integration flow. Orange: model path and safety hook.
Green: private data access and document ingestion. Dashed: optional or standby.

DOCUMENT INGESTION PATH (OFFLINE)

New or changed document in Blob raises an event, the queue feeds the ingestion workers, and ACLs are stored with every chunk in the index.
The raw copy stays immutable so the index can always be rebuilt.

Platform security, delivery and operations (shared, inherited by every application)

Entra workload ID — No secrets in pods
Key Vault — Keys, certificates
ACR Premium — Signed images
Azure DevOps — Private agents, GitOps
Azure Monitor — Logs, metrics, alerts
App Insights — End-to-end traces
Azure Policy — Approved configuration
Defender for Cloud — Posture, containers
Private DNS — Resolver, private zones

PROPOSED DESIGN, 24 OCT 2026. Model names and versions are deliberately generic: confirm regional availability and deployment type against Microsoft documentation and bank residency rules.

Icons: Microsoft Azure Public Service Icons V24. Employees, HR documents and Bank HR systems are generic boxes. Review notes and sizing on sheet 08.

08 | Review of the reference design and production readiness

What was kept, what was changed on sheet 07, and what must be true before go-live. Figures marked illustrative are placeholders for measured data.

Review of the reference diagram

Kept as is
AKS-hosted agents behind APIM; model calls through a gateway; ACL-filtered retrieval; confirmed actions with approval and idempotency; optional OCR and voice with their own budget; Service Bus Premium for durable jobs.

Changed or added on sheet 07
1. Identity: Entra token validation and on-behalf-of tokens for HR tools.
2. Safety: Content Safety and Prompt Shields in the model path.
3. Speed and cost: Redis for session memory and semantic cache.
4. HR path: Azure Firewall and ExpressRoute between the tool gateway and bank HR systems.
5. Resilience: secondary region with drilled failover.
6. Isolation: "same APIM, logical role" becomes separate products, policies and subscriptions per role; separate instances if audit requires.
7. Clean-up: crossing lines and the stray "Sheet.11" label removed; model names kept generic.

Capacity sizing, worked example (illustrative)

10,000 registered users
× 5% concurrent at peak = 500 users
× 0.5 requests per minute each = 250 requests per minute
× 3,500 tokens per request (prompt, retrieved context, answer) = 875,000 tokens per minute
+ 50% headroom = about 1.3 million tokens per minute quota at the AI gateway

Then size the rest from that number
Pods: start with at least 2 per zone for availability, then set autoscaling from measured per-pod concurrency in a load test.
Search: 2 or more replicas for read availability. Cosmos DB: autoscale throughput. Redis: zone-redundant.
Gateway: also a per-user fair-use limit, so one user cannot consume the app budget.

Failure modes and mitigations

Model throttled or down: gateway retries on a second deployment, spills to pay-as-you-go, fails over to the secondary region; degrade to search-only answers.
Search slow or unavailable: timeout, citations-only message, replica.
HR API down: circuit breaker; policy answers continue, actions are blocked and the user is told.
Duplicate or replayed action: idempotency key; dead-letter queue reviewed by a person.
Prompt injection in documents: document attack detection, content isolation, tool allowlist, no write without confirmation.
Stale or poisoned index: versioned ingestion, rebuild from the Blob source, ACL changes synced on a schedule.
Cost runaway: token budget per app and per user, alert at 80%, hard stop at 100%.

Operate and release (proposed targets)

SLOs: availability 99.9% a month; p95 time to first token under 3 seconds (validate by load test); groundedness above the agreed threshold on the evaluation set.
Disaster recovery: RTO 4 hours, RPO 15 minutes for conversation and action state; the index is rebuilt from Blob.
Release gates: evaluation set (quality, safety, red team), security scan, cost estimate, load test, policy check. Canary by namespace; rollback through GitOps.
Monitor: latency and errors, token use per app and per user, safety blocks, approval queue age, dead-letter count, empty-retrieval rate.
Audit: prompts, responses and tool calls logged with PII redaction; retention per bank policy.
Ownership: the app team owns its namespace; the platform team owns gateway, cluster and policies.